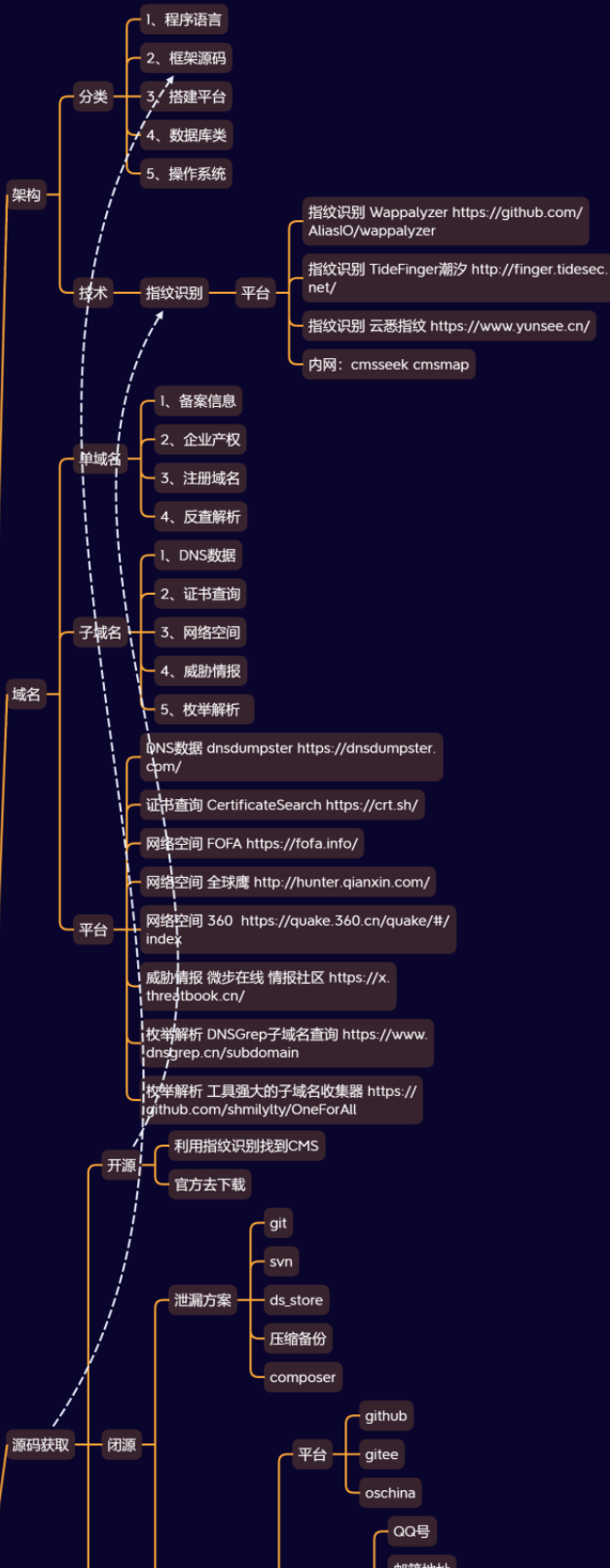


Day16 信息打点-CDN绕过&业务部署&漏洞回链 &接口探针&全网扫描&反向邮件

业务资产

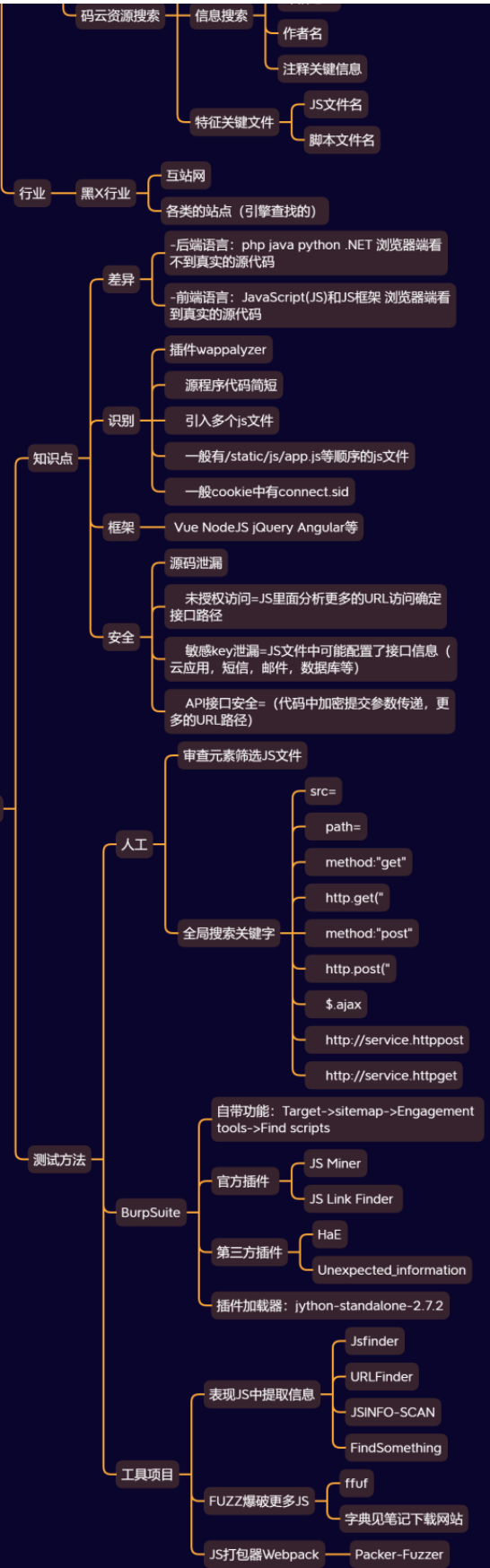
- 查询平台
 - 爱企查
 - 小蓝本
- 业务类型
 - 1、WEB应用
 - 2、APP应用
 - 3、PC端应用
 - 4、小程序应用
 - 5、微信公众号
 - 6、其他产品等



信息打点-小迪安全

① Web应用

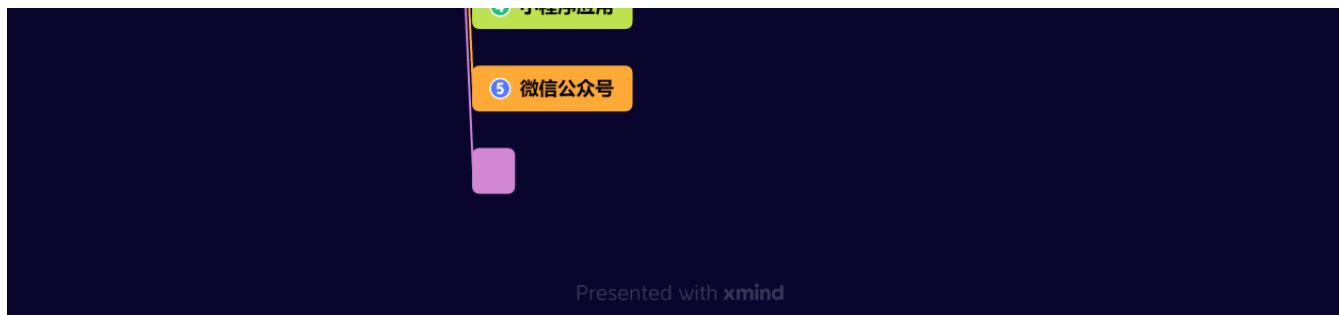
JS前端架构



② APP应用

③ PC应用

小程序应用



1.知识点

- 1、业务资产-应用类型分类
- 2、Web单域名获取-接口查询
- 3、Web子域名获取-解析枚举
- 4、Web架构资产-平台指纹识别

-
- 1、开源-CMS指纹识别源码获取方式
 - 2、闭源-习惯&配置&特性等获取方式
 - 3、闭源-托管资产平台资源搜索监控

-
- 1、JS前端架构-识别&分析
 - 2、JS前端架构-开发框架分析
 - 3、JS前端架构-打包器分析
 - 4、JS前端架构-提取&FUZZ

解决:

- 1、如何从表现中的JS提取价值信息
- 2、如何从地址中FUZZ提取未知的JS文件
- 3、如何从JS开放框架Webpack进行测试

-
- 1、端口扫描-应用&协议
 - 2、WAF识别-分类&识别
 - 3、蜜罐识别-分类&识别

解决:

- 1、Web服务器&应用服务器差异性
- 2、WAF防火墙&安全防护&识别技术
- 3、蜜罐平台&安全防护&识别技术

-
- 1、CDN 服务-解释差异识别

- 2、CDN 绕过-配置差异导致
- 3、CDN 绕过-主动连接获取
- 4、CDN 绕过-全网扫描获取

解决:

- 1、CDN 服务对安全影响
 - 2、CDN 服务绕过识别手法
-

2.详细点



- 1 CMS
- 2 Discuz、WordPress、Ecshop、蝉知等



- 1 前端技术
- 2 HTML5、jquery、bootstrap、Vue等



- 1 开发语言
- 2 PHP、JAVA、Ruby、Python、C#，JS等



- 1 web服务器
- 2 Apache、Nginx、IIS、lighttpd，Apache等



- 1 应用服务器:
- 2 Tomcat、Jboss、Weblogic、Websphere等



- 1 数据库类型:
- 2 Mysql、SqlServer、Oracle、Redis、MongoDB等



- 1 操作系统信息
- 2 Linux、windows等



- 1 应用服务信息:
- 2 FTP、SSH、RDP、SMB、SMTP、LDAP、Rsync等



- 1 CDN信息
- 2 帝联、Cloudflare、网宿、七牛云、阿里云等



- 1 WAF信息
- 2 创宇盾、宝塔、ModSecurity、玄武盾、OpenRASP等。



- 1 蜜罐信息:
- 2 HFish、TeaPot、T-Pot、Glastopf等



- 1 其他组件信息
- 2 fastjson、shiro、log4j、OA办公等

3.演示案例



- 1 #前置知识:
- 2 1.传统访问: 用户访问域名->解析服务器IP->访问目标主机
- 3 2.普通CDN: 用户访问域名->CDN节点->真实服务器IP->访问目标主机
- 4 3.带WAF的CDN: 用户访问域名->CDN节点(WAF)->真实服务器IP->访问目标主机
- 5
- 6 国内服务商:
- 7 阿里云 百度云 七牛云
- 8 又拍云 腾讯云 Ucloud
- 9 360 网宿科技 ChinaCache
- 10
- 11 国外服务商
- 12 CloudFlare StackPath Fastly
- 13 Akamai CloudFront Edgecast
- 14 CDNetworks Google Cloud CDN
- 15 CacheFly Keycdn Udomain CDN77
- 16
- 17 #CDN配置:
- 18 配置1: 加速域名-需要启用加速的域名
- 19 配置2: 加速区域-需要启用加速的地区
- 20 配置3: 加速类型-需要启用加速的资源
- 21
- 22 #参考知识:
- 23 超级Ping: <http://www.17ce.com/>
- 24 超级Ping: <https://ping.chinaz.com/>
- 25 接口查询: <https://get-site-ip.com/>
- 26 接口查询: <https://fofa.info/extensions/source>
- 27 国外请求: <https://tools.ipip.net/cdn.php>

28 国外请求: <https://boce.aliyun.com/detect/>
29 IP社区库: <https://www.cz88.net/geo-public>
30 全网扫描: <https://github.com/Tai7sy/fuckcdn>
31 全网扫描: <https://github.com/boy-hack/w8fuckcdn>
32 全网扫描: https://github.com/Pluto-123/Bypass_cdn
33
34 <https://mp.weixin.qq.com/s/zxEH-HMqKukmq7qxfrdnQQ>
35 常见方法:
36 子域名, 邮件系统, 国外访问, 证书查询, APP抓包, 网络空间
37 通过漏洞或泄露获取, 扫全网, 以量打量, 第三方接口查询等

3.1 前置后置-CDN服务-识别&绑定访问


1 超级Ping: <http://17ce.com/>
2 超级Ping: <https://ping.chinaz.com/>
3 各地ping (出现多个IP即启用CDN服务)
4 后置: 绑定HOST访问解析 (参考基础课CDN安全影响)

3.2 某应用-CDN绕过-主动漏洞&遗留文件


1 配置加速选项中只加速主域名, 导致其他子域名未加速 (解析IP可能同IP也可能C段)
2 接口查询: <https://get-site-ip.com/>
3 接口查询: <https://fofa.info/extensions/source>
4 使用网络空间&第三方功能集合查询判断

3.3 某应用-CDN绕过-主动漏洞&遗留文件


1 1、漏洞如: SSRF RCE等
2 利用漏洞让对方真实服务器主动出网连接, 判断来源IP即真实IP
3 2、遗留文件: phpinfo类似功能
4 通过访问类似PHPINFO类似代码函数获取本地IP造成的地址泄漏

3.4 某应用-CDN绕过-邮件系统


1 判断条件: 发信人是当前域名邮件用户名
2 -让他主动给你发:
3 部署架设的邮件服务器如果向外部用户发送邮件的话,
4 那么邮件头部的源码中会包含此邮件服务器的真实IP地址。
5 常见的邮件触发点有:
6 1、RSS订阅
7 2、邮箱注册、激活处
8 3、邮箱找回密码处
9 4、产品更新的邮件推送
10 5、某业务执行后发送的邮件通知

- 11 6、员工邮箱、邮件管理平台等入口处的忘记密码
- 12 -你给未知邮箱发：（需要自己的邮件服务器不能第三方）
- 13 通过发送邮件给一个不存在的邮箱地址，因为该用户邮箱不存在，所以发送将失败，
- 14 并且还会收到一个包含发送该电子邮件给你的服务器的真实IP通知。

3.5 某应用-CDN绕过-全网扫描

- 
- 1 1、判断加速厂商
 - 2 2、IP库筛地址段
 - 3 3、配置范围扫描
 - 4 先从IP段去扫描符合开放端口，再从IP去访问看看关键字，将符合结果进行保存！
 - 5 厂商查询：
 - 6 <https://tools.ipip.net/cdn.php>
 - 7 工具项目：
 - 8 <https://www.cz88.net/geo-public>
 - 9 <https://github.com/Tai7sy/fuckcdn>